Enforce Least-Privilege Access Through Identity-Aware, Application-Specific Access Policies Using Zscaler Private Access (ZPA).

Group Details:

S.NO	NAME	COLLEGE	CONTACT
1	Mushraf khan M	Texcity Arts & Science College	mushrraf.0310.siya@gmail.com
2	Jayakrishnamoorthi R	Texcity Arts & Science College	ravanakrish9786@gmail.com
3	Ahamed suhaib S	Texcity Arts & Science College	suhaibsahvi1122@gmail.com
4	Anees ahamed M	Texcity Arts & Science College	anees191196@gmail.com
5	Harishma B	Texcity Arts & Science College	tamilharish001@gmail.com

INTRODUCTION

In an era where the digital landscape is constantly evolving, organizations face an ever-increasing threat from cyberattacks. The need for swift and effective incident response has become paramount to safeguard sensitive data, protect digital assets, and maintain the trust of stakeholders. In response to this growing challenge, we present a visionary project: the development of an AI-driven incident response platform that empowers cybersecurity teams with the tools to automate and enhance incident triage and response tasks.

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, modern enterprises are rapidly shifting away from legacy VPN-centric remote access models. These conventional approaches often grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement. To address these challenges, this project centers on the implementation of a Zero Trust security architecture, fundamentally operating on the principle of "never trust, always verify." By moving beyond location-based access, we aim to establish a security posture where trust is no longer implicit, and access is determined by granular context rather than network connectivity.

The core of this initiative involves the deployment of Zscaler Private Access (ZPA), a cloud-delivered Zero Trust Access solution designed to create identity-aware, application-specific connectivity. Unlike traditional VPNs that place users on the internal network, ZPA leverages a "service-initiated" model to establish direct, one-to-one connections between authorized users and specific applications, completely hiding the corporate network and IP address space from the internet. This ensures that users connect exclusively to the applications they are permitted to access, based on continuous identity verification and context, rendering the applications invisible to unauthorized users and preventing common attack vectors such as port scanning and distributed denial-of-service (DDoS) attacks.

Ultimately, this project will enforce a least-privilege access model, ensuring users and devices are granted the minimum required access necessary to perform their functions. By decoupling application access from network access, we will eliminate the risk of lateral movement across the network, as users have no visibility or connectivity to other hosts. This strategic move not only significantly enhances security by reducing the attack surface but also simplifies the user experience and reduces operational overhead associated with legacy remote access infrastructure, positioning the organization at the forefront of secure and efficient access management.

ABSTRACT

The proliferation of hybrid work and cloud-based resources has rendered traditional perimeter-based security models, such as VPNs, obsolete and increasingly dangerous. These legacy solutions often provide overly broad network access, exposing organizations to significant risks including lateral threat movement and an expanded attack surface. This project addresses these vulnerabilities by implementing a Zero Trust Architecture (ZTA) utilizing Zscaler Private Access (ZPA). The primary objective is to transition from network-centric to identity-centric access, thereby enforcing the principle of least privilege.

The methodology involves deploying ZPA's cloud-based service to create application-specific, identity aware micro-tunnels. Unlike conventional VPNs that place users on the internal network, this solution establishes direct, one-to-one connections between verified users and authorized applications. The network infrastructure and all non-authorized applications remain completely invisible to the end-user, effectively eliminating surface for reconnaissance and attack. Access policies are dynamically governed by user identity, device posture, and contextual attributes, ensuring that connectivity is strictly limited to what is explicitly required for specific job functions.

The implementation of ZPA successfully decouples application access from network access, resulting in a demonstrable reduction in the organization's attack surface and the complete prevention of lateral movement. This project delivers a robust, scalable, and user-friendly remote access framework that aligns with modern security best practices. By shifting to an identity-aware, least-privilege model, the organization significantly enhances its security posture while simultaneously reducing operational complexity and improving the end-user experience.

USE CASE SCENARIOS

Scenario 1: Finance Department Access to ERP System

A senior accountant in the finance department needs to access the corporate Enterprise Resource Planning (ERP) system to process monthly payroll. The user connects from a remote location using their company-managed laptop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with multi-factor authentication (MFA). ZPA evaluates the user's identity, group membership (Finance_ERP_Users), device posture (antivirus active, disk encryption enabled), and connection context. The policy engine determines that the user is authorized and brokers a secure, direct micro-tunnel to the ERP application only. The user can interact with the ERP interface, but has no visibility or network-level access to any other internal systems, such as development servers or the HR database.

Output:

- User authenticated and authorized based on identity and group membership.
- Direct micro-tunnel established specifically to the ERP application.
- All other internal applications and network segments remain invisible and inaccessible.

Scenario 2: Contractor Access to Specific Project Repository

An external software consultant is hired for a three-month project and requires access only to a specific Git repository hosted on an internal server. The contractor is onboarded as a guest user in the identity provider and assigned to the "Project_X_Contractors" group. When the contractor connects using the ZPA client, the system verifies their identity and checks the device for basic security compliance (OS patch level, firewall enabled). ZPA enforces a policy that grants access exclusively to the Git repository application (port 22/SSH or port 443/HTTPS) during business hours (9 AM to 5 PM). The contractor can clone, push, and pull code, but cannot discover or connect to any other internal resources, including the corporate intranet or file servers.

Output:

- Time-bound and role-specific access enforced.
- Contractor restricted to a single application (Git repository).
- Lateral movement to adjacent systems completely blocked.

Scenario 3: Executive Access to Confidential Board Documents

A company executive needs to access a confidential folder containing board meeting materials hosted on an internal file server. The executive connects from a tablet device while traveling internationally. ZPA integrates with the mobile device management (MDM) solution to verify that the tablet is compliant (not jailbroken, passcode enabled, encryption active). Upon successful authentication, ZPA evaluates the policy: "If user is in 'Executive_Board' group AND device is MDM-compliant AND connection is from a trusted country (allowlist), THEN grant access to 'Board_Documents' application." The executive is connected directly to the specific file share, and all data in transit is encrypted via TLS. Any attempt to access other shares or network resources is automatically blocked and logged.

Output:

- Context-aware access based on user role, device posture, and geographic location.
- Granular access to a specific file share (Board_Documents) .
- Comprehensive logging of access events for audit and compliance.

Scenario 4: IT Administrator Access to Server Management Interfaces

A systems administrator requires access to management interfaces (SSH for Linux servers and RDP for Windows servers) to perform routine maintenance. Instead of granting VPN access to the entire management network, ZPA is configured to treat each server or management interface as a separate application segment. The administrator authenticates and is presented only with the specific servers they are authorized to manage based on their IT subgroup (e.g., "Linux_Admins" see only Linux servers; "Windows_Admins" see only Windows servers). When the admin connects via SSH to a Linux server, ZPA creates a direct micro-tunnel to that specific IP and port combination. The admin cannot scan the subnet, access other servers, or initiate connections to non-authorized ports.

Output:

- Micro-segmentation at the individual server/interface level .

- Role-based access controlling visibility of specific management consoles .
- Elimination of network-level reconnaissance capabilities for admins.

Scenario 5: Mergers and Acquisitions Integration

A company acquires a smaller firm and needs to provide the acquired company's HR team with temporary access to the parent company's benefits enrollment application. The acquired company's users are added as external collaborators in the identity provider with limited attributes. ZPA policies are created that specifically grant the "Acquired_HR" group access only to the "Benefits_App" (a web application hosted internally). The acquired users install the ZPA client, authenticate, and are connected directly to the benefits application. Because ZPA provides access without network connectivity, the parent company's entire internal network remains completely hidden and protected. The acquired users cannot ping, scan, or access any other corporate resource. After six months, when the integration is complete and users are migrated to the parent identity system, the temporary policies are revoked.

Output:

- Secure, temporary access provided without network exposure.
- Complete network invisibility protecting the parent company's infrastructure.
- Simplified deprovisioning through policy revocation rather than complex network changes.

STAGE 1

Title : OWASP Top 10

OVERVIEW

The **OWASP Top 10** is a globally recognized awareness document that identifies the most critical security risks affecting web applications. It is designed to help developers, security professionals, and organizations understand common vulnerabilities and implement better security practices throughout the software development lifecycle. By highlighting the most frequently exploited weaknesses, the OWASP Top 10 serves as a practical guide for improving application security and reducing the risk of cyberattacks.

The OWASP Top 10 covers major security issues that commonly lead to system compromise and data breaches. These risks include **Broken Access Control**, where users can access resources or perform actions beyond their permissions, and **Cryptographic Failures**, where sensitive data is not properly protected through encryption. **Injection attacks**, such as SQL injection, occur when untrusted input is interpreted as commands or queries by an application. Additionally, **Insecure Design** arises from poor architectural decisions that fail to consider security during the design phase of a system.

Other important risks include **Security Misconfiguration**, which occurs when systems are deployed with incorrect or default settings that expose vulnerabilities. **Vulnerable and Outdated Components** refer to the use of third-party libraries or frameworks with known security flaws. **Identification and Authentication Failures** may allow attackers to bypass login mechanisms or impersonate legitimate users. **Software and Data Integrity Failures** occur when applications do not verify the integrity of software updates or external code.

The list also includes **Security Logging and Monitoring Failures**, where insufficient logging prevents organizations from detecting or responding to attacks in time. Another significant risk is **Server-Side Request Forgery (SSRF)**, where attackers manipulate a server into making unauthorized requests to internal or external systems. By understanding and addressing these vulnerabilities, organizations can strengthen their security posture, protect sensitive data, and maintain the reliability and trustworthiness of their applications.

List of Vulnerability:

S.NO	Vulnerability Name	CWE / CVE No.
1	Absolute Path Traversal	CWE - 36
2	Sensitive Cookie in HTTPS Session Without 'Secure' Attribute	CWE - 614
3	Use of Unmaintained Third Party Components	CWE - 1104
4	Weak Encoding for Password	CWE - 261
5	Improper Input Validation	CWE - 20
6	Missing Encryption of Sensitive Data	CWE - 311
7	Improper Authentication	CWE - 287
8	Embedded Malicious Code	CWE - 506
9	Information Loss or Omission	CWE - 221
10	Divide By Zero	CWE - 369

Report:

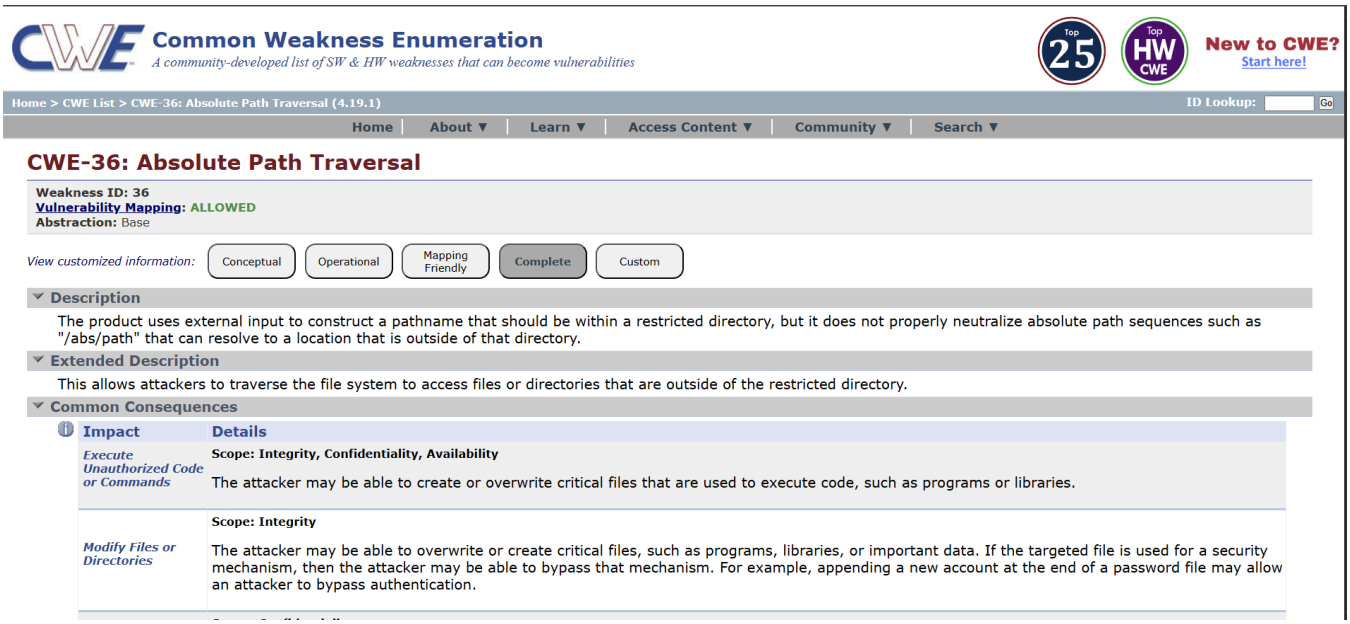
1. Vulnerability Name : Absolute Path Traversal

CWE/CVE No : CWE - 36

Owasp Category : A01:2025 Broken Access Control

Description : The product uses external input to construct a pathname that should be within a restricted directory, but it does not properly neutralize absolute path sequences such as "/abs/path" that can resolve to a location that is outside of that directory.

Business Impact : Absolute path traversal vulnerabilities can enable attackers to access restricted files on the server, potentially exposing confidential data, application secrets, or system configuration information that could compromise the entire system.



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-36: Absolute Path Traversal (4.19.1)

ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-36: Absolute Path Traversal

Weakness ID: 36
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product uses external input to construct a pathname that should be within a restricted directory, but it does not properly neutralize absolute path sequences such as "/abs/path" that can resolve to a location that is outside of that directory.

Extended Description

This allows attackers to traverse the file system to access files or directories that are outside of the restricted directory.

Common Consequences

Impact	Details
Execute Unauthorized Code or Commands	**Scope: Integrity, Confidentiality, Availability** The attacker may be able to create or overwrite critical files that are used to execute code, such as programs or libraries.
Modify Files or Directories	**Scope: Integrity** The attacker may be able to overwrite or create critical files, such as programs, libraries, or important data. If the targeted file is used for a security mechanism, then the attacker may be able to bypass that mechanism. For example, appending a new account at the end of a password file may allow an attacker to bypass authentication.

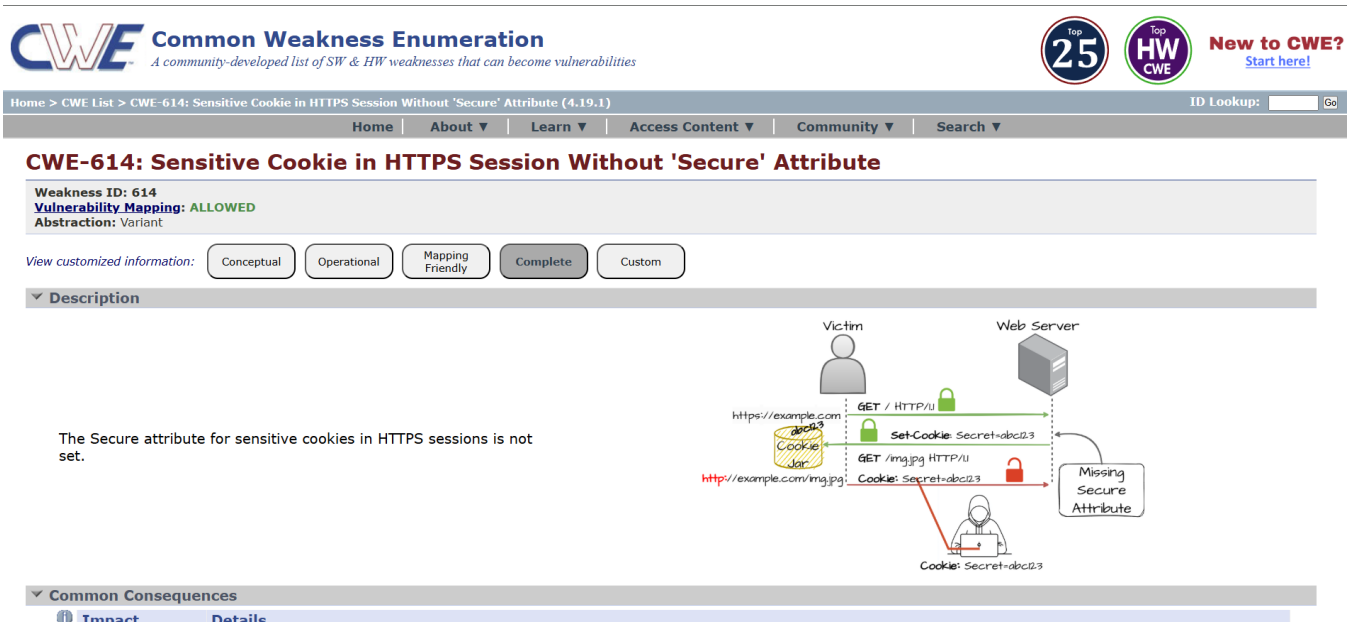
2. **Vulnerability Name :** Sensitive Cookie in HTTPS Session Without 'Secure' Attribute

CWE/CVE No : CWE - 614

Owasp Category : A02:2025 - Security Misconfiguration

Description : This vulnerability occurs when a web application sets sensitive cookies such as session IDs or authentication tokens over HTTPS but fails to include the Secure attribute. Without this attribute, the browser may transmit the cookie over an unencrypted HTTP connection, making it possible for attackers on the network to intercept the cookie. If an attacker captures the session cookie, they may hijack the user's session and gain unauthorized access to the application.

Business Impact : Missing the Secure attribute on sensitive cookies can allow attackers to intercept session data, leading to session hijacking, unauthorized account access, exposure of sensitive information, and potential financial, legal, and reputational damage to the organization.



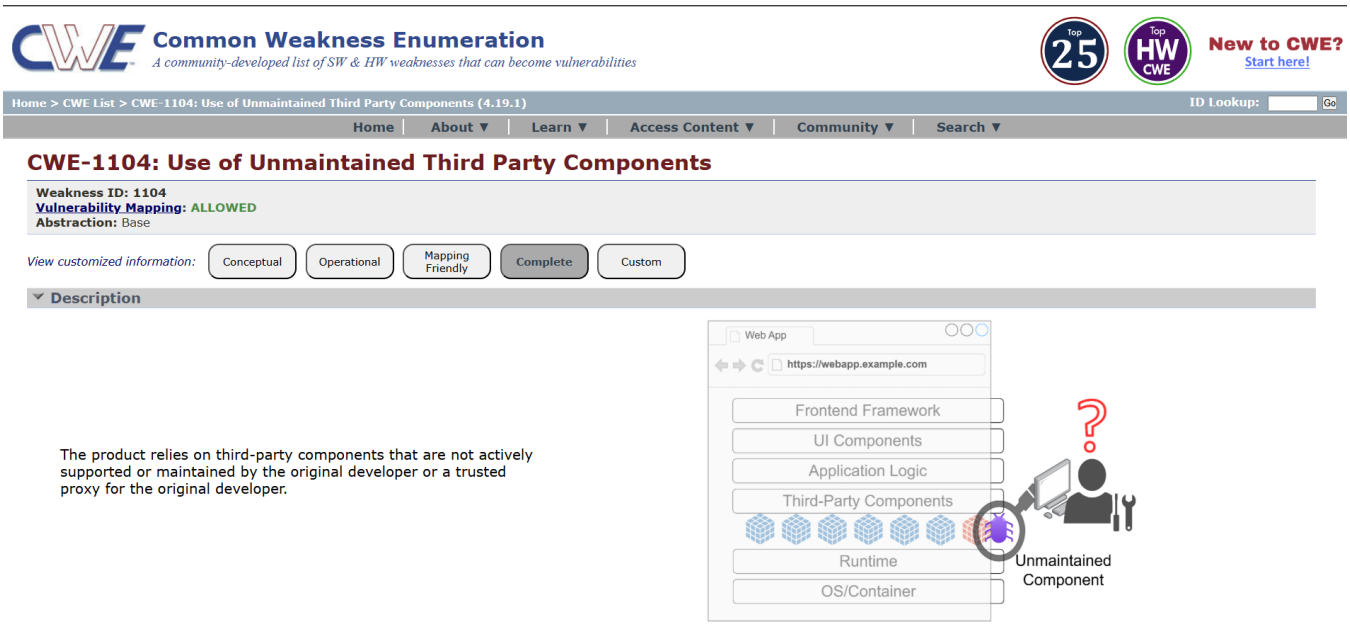
3. Vulnerability Name : Use of Unmaintained Third Party Components

CWE/CVE No : CWE - 1104

Owasp Category : A03:2025 - Software Supply Chain Failures

Description : This vulnerability occurs when an application depends on third-party libraries, frameworks, or components that are no longer actively maintained or supported by their developers. Because these components do not receive security updates, bug fixes, or patches, any newly discovered vulnerabilities remain unaddressed. Attackers may exploit these known weaknesses to compromise the application or underlying system.

Business Impact : Using unmaintained third-party components increases the risk of exploitation through known vulnerabilities, which can lead to system compromise, data breaches, service disruption, regulatory compliance issues, and reputational damage for the organization.



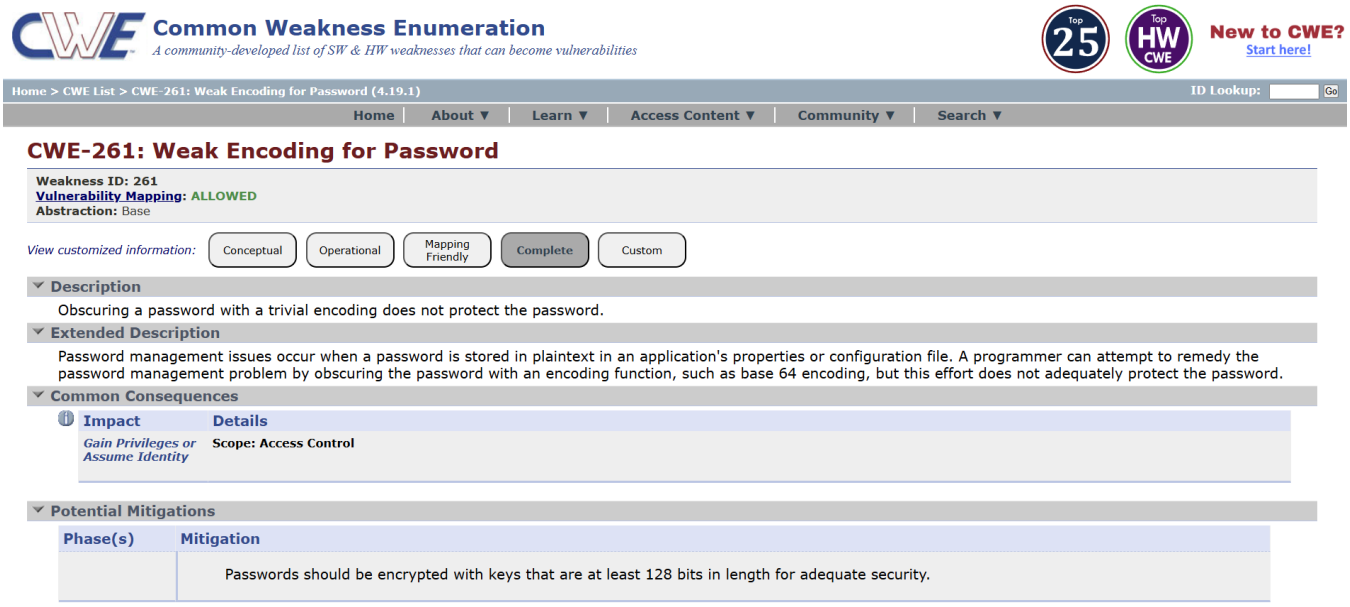
4. Vulnerability Name : Weak Encoding for Password

CWE/CVE No : CWE - 261

Owasp Category : A04:2025 Cryptographic Failures

Description : This vulnerability occurs when an application stores or processes passwords using weak encoding mechanisms such as Base64 or other reversible encoding techniques instead of strong cryptographic hashing. Because encoding methods are easily reversible, attackers who gain access to encoded passwords can quickly decode them and retrieve the original plaintext passwords, compromising user accounts.

Business Impact : Weak encoding of passwords can allow attackers to easily recover user credentials if the data is exposed, leading to account compromise, unauthorized access to systems, potential data breaches, regulatory penalties, and damage to the organization's reputation.



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-261: Weak Encoding for Password (4.19.1)

ID Lookup:

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-261: Weak Encoding for Password

Weakness ID: 261
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

Obscuring a password with a trivial encoding does not protect the password.

Extended Description

Password management issues occur when a password is stored in plaintext in an application's properties or configuration file. A programmer can attempt to remedy the password management problem by obscuring the password with an encoding function, such as base 64 encoding, but this effort does not adequately protect the password.

Common Consequences

Impact	Details
Gain Privileges or Assume Identity	**Scope: Access Control**

Potential Mitigations

Phase(s)	Mitigation
	Passwords should be encrypted with keys that are at least 128 bits in length for adequate security.

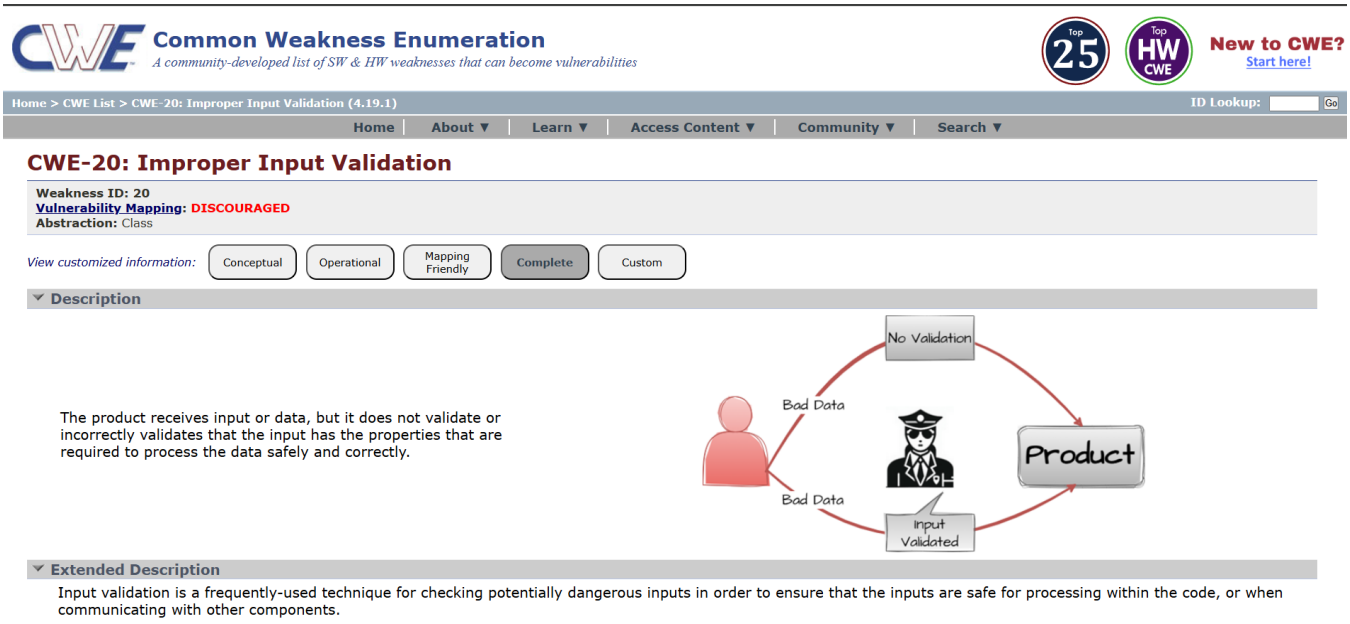
5. **Vulnerability Name :** Improper Input Validation

CWE/CVE No : CWE - 20

Owasp Category : A05:2025 Injection

Description : This vulnerability occurs when an application fails to properly validate or sanitize user input before processing it. If input data from users, forms, APIs, or external systems is not strictly checked for type, length, format, or allowed values, attackers may submit malicious input that manipulates application behavior or exploits underlying systems.

Business Impact : Improper input validation can allow attackers to inject malicious data, potentially leading to system compromise, data manipulation, unauthorized access, application crashes, and significant financial, operational, and reputational damage to the organization.



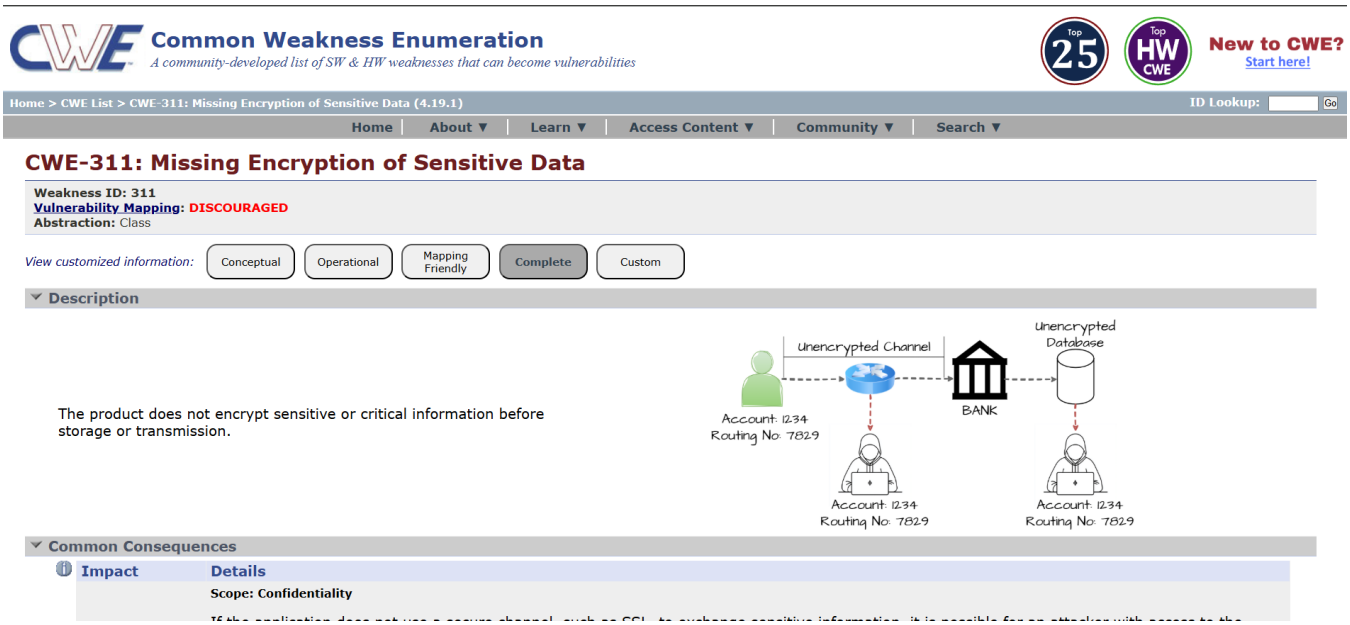
6. Vulnerability Name : Missing Encryption of Sensitive Data

CWE/CVE No : CWE - 311

Owasp Category : A06:2025 Insecure Design

Description : This vulnerability occurs when sensitive information such as passwords, personal data, financial details, or confidential business data is transmitted or stored without proper encryption. Without encryption, the data can be easily intercepted, read, or modified by unauthorized parties during transmission or storage.

Business Impact : Missing encryption for sensitive data can lead to unauthorized disclosure of confidential information, resulting in data breaches, financial loss, regulatory penalties, legal liabilities, and significant damage to the organization's reputation.



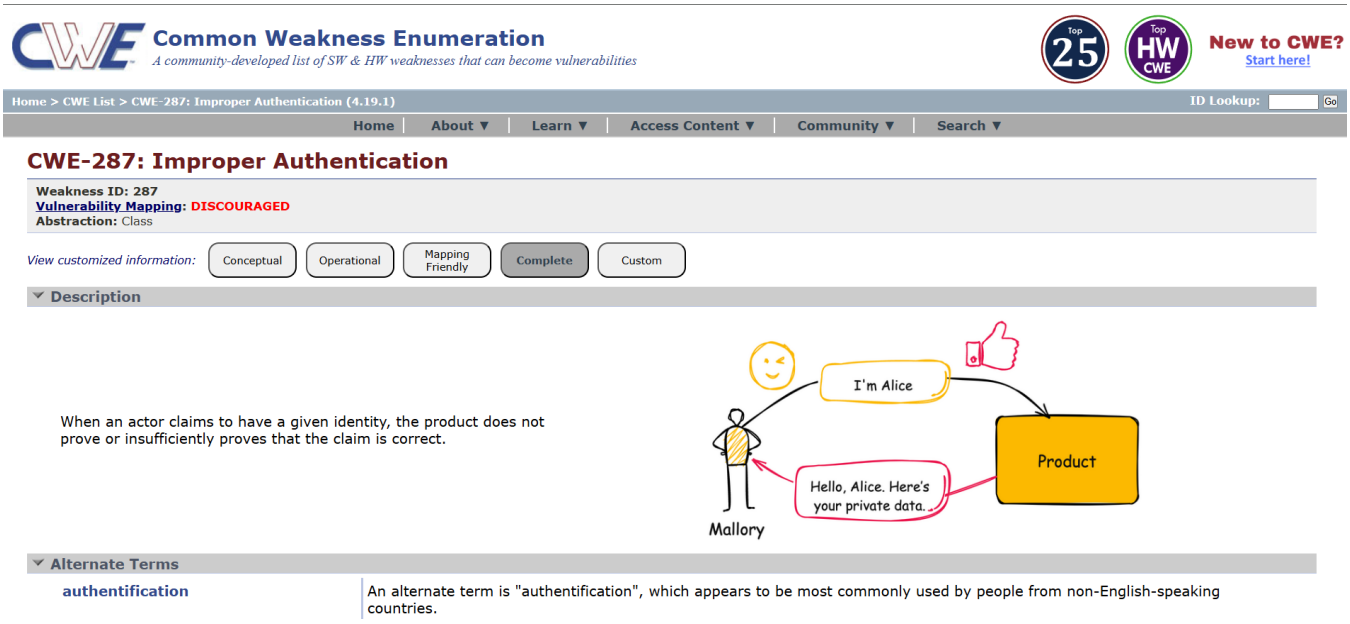
7. Vulnerability Name : Improper Authentication

CWE/CVE No : CWE - 287

Owasp Category : A07:2025 Authentication Failures

Description : This vulnerability occurs when an application fails to properly verify the identity of users before granting access to protected resources or functionalities. Weak or flawed authentication mechanisms such as missing authentication checks, predictable credentials, or flawed login logic may allow attackers to bypass authentication controls.

Business Impact : Improper authentication can allow attackers to gain unauthorized access to user accounts or critical systems, potentially leading to data breaches, service disruption, financial losses, and reputational damage for the organization.



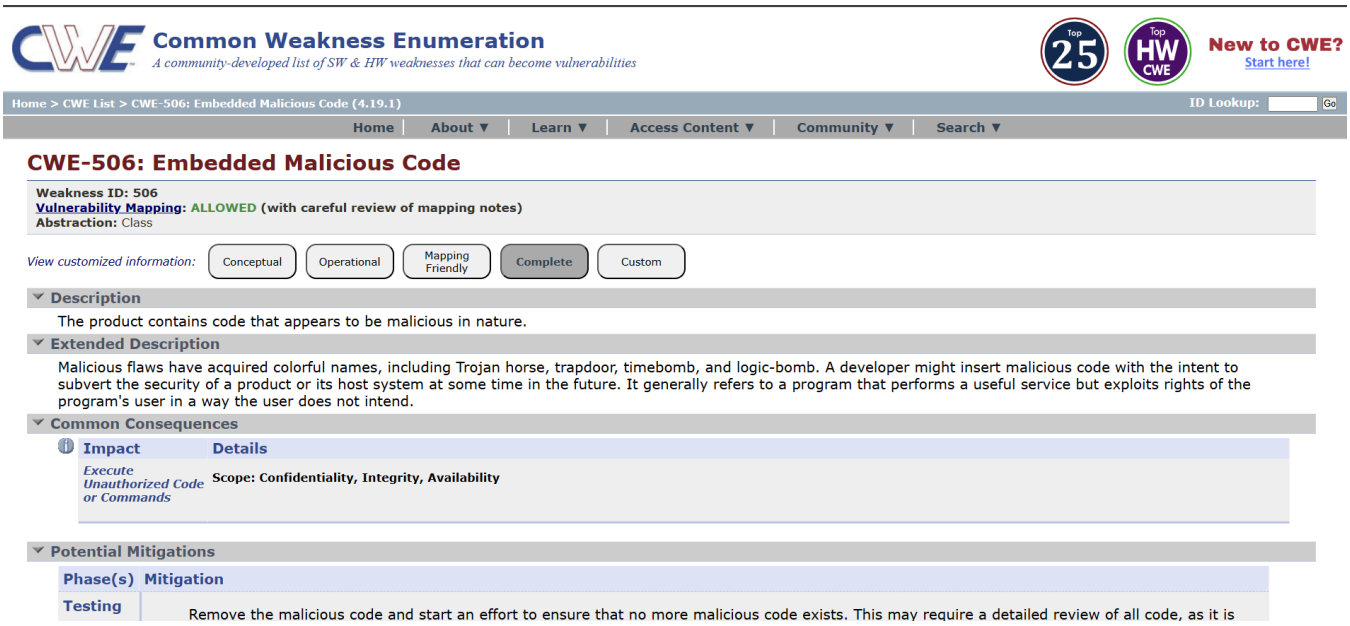
8. Vulnerability Name : Embedded Malicious Code

CWE/CVE No : CWE - 506

Owasp Category : A08:2025 Software or Data Integrity Failures

Description : This vulnerability occurs when malicious code is intentionally embedded within an application or software component. The hidden code may perform unauthorized actions such as creating backdoors, leaking sensitive data, bypassing security controls, or executing harmful operations without the knowledge of users or administrators.

Business Impact : Embedded malicious code can compromise system integrity and confidentiality, potentially allowing attackers to steal sensitive data, gain persistent unauthorized access, disrupt services, and cause significant financial, operational, and reputational damage to the organization.



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-506: Embedded Malicious Code (4.19.1)

ID Lookup:

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-506: Embedded Malicious Code

Weakness ID: 506
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product contains code that appears to be malicious in nature.

Extended Description

Malicious flaws have acquired colorful names, including Trojan horse, trapdoor, timebomb, and logic-bomb. A developer might insert malicious code with the intent to subvert the security of a product or its host system at some time in the future. It generally refers to a program that performs a useful service but exploits rights of the program's user in a way the user does not intend.

Common Consequences

Impact	Details
Execute Unauthorized Code or Commands	**Scope: Confidentiality, Integrity, Availability**

Potential Mitigations

Phase(s)	Mitigation
Testing	Remove the malicious code and start an effort to ensure that no more malicious code exists. This may require a detailed review of all code, as it is

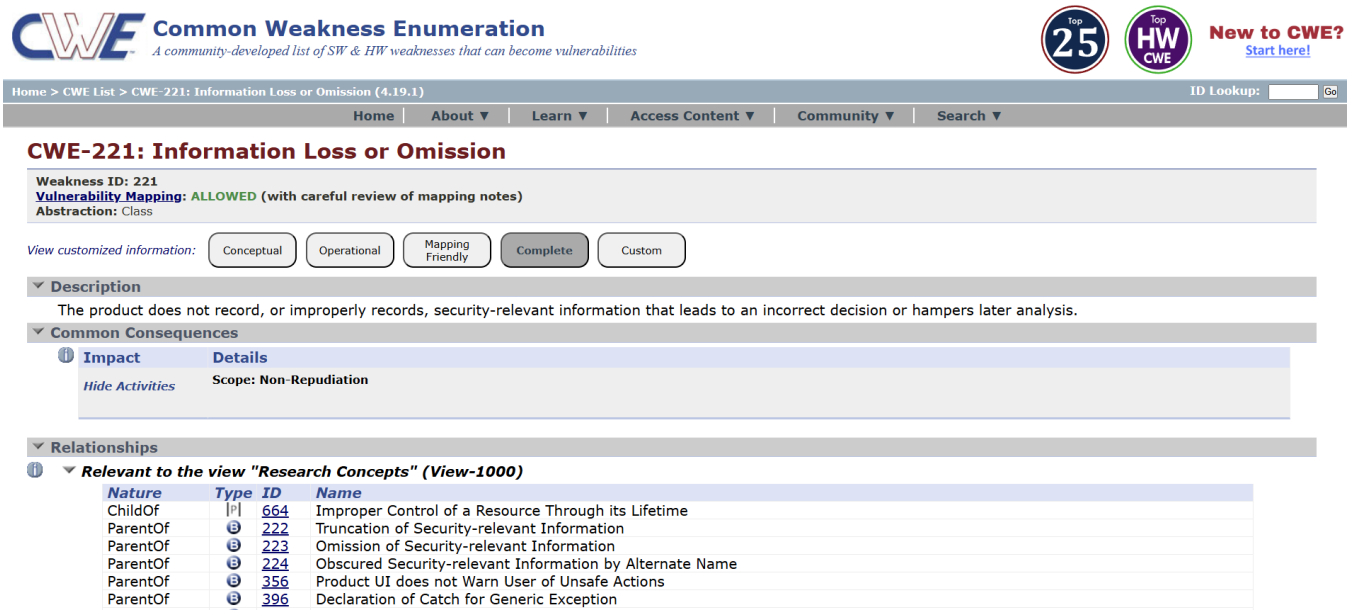
9. Vulnerability Name : Information Loss or Omission

CWE/CVE No : CWE - 221

Owasp Category : A09:2025 Security Logging & Alerting Failures

Description : This vulnerability occurs when important information is accidentally lost, omitted, or not properly preserved during data processing, logging, transmission, or storage. Such omissions may happen due to improper system design, incomplete data handling, or incorrect implementation of data validation and logging mechanisms, which can result in incomplete or inaccurate information being recorded or processed.

Business Impact : Information loss or omission can lead to inaccurate records, compliance issues, operational errors, and difficulty in auditing or incident investigation, potentially resulting in financial loss, legal risks, and reduced trust in the organization’s systems and services.



Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-221: Information Loss or Omission (4.19.1)

ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

CWE-221: Information Loss or Omission

Weakness ID: 221
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product does not record, or improperly records, security-relevant information that leads to an incorrect decision or hampers later analysis.

Common Consequences

Impact	Details
Hide Activities	**Scope: Non-Repudiation**

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf	P	664	Improper Control of a Resource Through its Lifetime
ParentOf	B	222	Truncation of Security-relevant Information
ParentOf	B	223	Omission of Security-relevant Information
ParentOf	B	224	Obscured Security-relevant Information by Alternate Name
ParentOf	B	356	Product UI does not Warn User of Unsafe Actions
ParentOf	B	396	Declaration of Catch for Generic Exception

10. Vulnerability Name : Divide By Zero

CWE/CVE No : CWE - 369

Owasp Category : A10:2025 Mishandling of Exceptional Conditions

Description : This vulnerability occurs when a program performs a division operation without checking whether the divisor is zero. If the divisor becomes zero during execution, the application may generate runtime errors, crash, or behave unexpectedly, which can disrupt normal application functionality.

Business Impact : Divide-by-zero vulnerabilities can cause application crashes or service disruptions, potentially leading to denial of service, reduced system reliability, operational downtime, and negative impact on business continuity and user trust.

STAGE 2

Title : NESSUS Scan

OVERVIEW

A **Nessus scan** is a widely used vulnerability assessment method for identifying security weaknesses in computer systems, networks, and applications. Nessus is developed by **Tenable** and is designed to help organizations detect vulnerabilities, misconfigurations, outdated software, and potential security risks before attackers can exploit them. It works by scanning systems, servers, databases, and network devices to compare them against a large database of known vulnerabilities and security issues.

During a Nessus scan, the tool analyzes the target system by checking open ports, installed software versions, system configurations, and security settings. It then identifies known vulnerabilities such as missing patches, weak encryption protocols, insecure services, and misconfigured access controls. Nessus uses regularly updated vulnerability plugins to ensure that newly discovered threats are also detected during the scanning process.

After the scan is completed, Nessus generates a detailed report that categorizes vulnerabilities based on severity levels such as **Critical, High, Medium, Low, and Informational**. The report also provides descriptions of each vulnerability, potential risks, and recommended remediation steps to help organizations fix the identified issues. Security teams often use these reports to prioritize vulnerabilities and improve their overall security posture.

Nessus scanning is commonly used in **vulnerability assessments, penetration testing, compliance auditing, and continuous security monitoring**. By regularly performing Nessus scans, organizations can proactively identify security weaknesses, reduce the risk of cyberattacks, and maintain a secure IT infrastructure.

S.NO	Vulnerability	Severity	Plugin
1	Service Detection	Info	22964
2	Nessus SYN Scanner	Info	11219
3	Additional DNS Hostnames	Info	46180
4	OS Fingerprints Detected	Info	209654
5	Traceroute Information	Info	10287

REPORT

1. **Vulnerability Name:** Service Detection

Severity : Info

Plugin : 22964

Description : Service Detection refers to the identification of running services and their corresponding ports on a system during a network scan. Tools such as Nessus detect open ports and determine the service type, version, and protocol running on those ports. While service detection itself is not always a vulnerability, it reveals information about the system's exposed services. Attackers can use this information to map the target environment and identify potential entry points or known vulnerabilities associated with those services.

Solution : To mitigate the risk of service detection, organizations should minimize the exposure of unnecessary services and close unused ports. Network security controls such as firewalls and access control lists should be implemented to restrict access to essential services only. Additionally, services should be kept updated with the latest security patches, and banner information that reveals service versions should be disabled where possible.

Business Impact : If service information is exposed, attackers may gain insight into the technologies and services running within the organization's infrastructure. This information can be used for reconnaissance, enabling attackers to identify outdated or vulnerable services and launch targeted attacks. As a result, it may increase the risk of unauthorized access, exploitation of vulnerabilities, and potential disruption of business operations.

2. Vulnerability Name : Nessus SYN Scanner

Severity : Info

Plugin : 11219

Description : The Nessus SYN Scanner performs a TCP SYN scan to identify open ports and active services on a target system. This technique sends a SYN packet to the target port and analyzes the response to determine whether the port is open, closed, or filtered. While this scanning method is commonly used for security assessments, it can reveal exposed services and network configurations. If such services are publicly accessible, attackers may use this information during reconnaissance to identify potential attack vectors.

Solution : Restrict unnecessary open ports and disable unused services on the system. Implement firewall rules and network segmentation to limit access only to trusted sources. Intrusion Detection/Prevention Systems (IDS/IPS) should be used to monitor and block suspicious scanning activities. Regular security assessments and timely patching of exposed services will further reduce the risk of exploitation.

Business Impact : Exposure of open ports and detectable services can provide attackers with valuable information about the organization's infrastructure. This reconnaissance data may help adversaries identify vulnerable services, outdated software, or misconfigured systems. Successful exploitation could lead to unauthorized access, data breaches, service disruption, or compromise of critical business systems.

3. Vulnerability Name : Additional DNS Hostnames

Severity : Info

Plugin : 46180

Description : The Additional DNS Hostnames finding indicates that multiple hostnames are associated with the same IP address in the Domain Name System (DNS). During scanning, Nessus identifies other DNS records that resolve to the target system. These hostnames may represent additional domains, subdomains, or services hosted on the same server. While this is typically an informational finding, it may reveal internal or unused hostnames that could provide attackers with additional targets for reconnaissance or further attacks.

Solution : Review all DNS records associated with the identified IP address and remove any unnecessary or outdated hostnames. Ensure that only required domains and subdomains are publicly accessible. Implement proper DNS management practices and regularly audit DNS configurations to prevent unintended exposure of internal or unused hostnames.

Business Impact : Exposure of additional DNS hostnames can provide attackers with more information about the organization's infrastructure and hosted services. This information may assist in reconnaissance activities, enabling attackers to identify hidden services, development environments, or misconfigured systems that could be exploited. In some cases, it may increase the attack surface of the organization.

4. Vulnerability Name : OS Fingerprints Detected

Severity : Info

Plugin : 209654

Description : The OS Fingerprints Detected finding indicates that the operating system of the target host can be identified through network scanning techniques. Using tools such as Nessus, the scanner analyzes network responses, TCP/IP stack behavior, and system characteristics to determine the probable operating system running on the target machine. This information disclosure may allow attackers to identify the underlying platform and tailor their attacks based on known vulnerabilities associated with that operating system.

Solution : Limit unnecessary exposure of system information by configuring firewalls, intrusion prevention systems, and network devices to restrict OS fingerprinting attempts. Disable unnecessary services and apply the latest security patches and updates to the operating system. Additionally, network security controls should be implemented to detect and block suspicious scanning activities.

Business Impact : If the operating system details are exposed, attackers can use this information during the reconnaissance phase to identify potential vulnerabilities specific to that OS. This may increase the likelihood of targeted attacks, exploitation of unpatched vulnerabilities, and unauthorized access to systems, which could lead to data compromise or disruption of business operations.

5. Vulnerability Name : Traceroute Information

Severity : Info

Plugin : 10287

Description : Traceroute Information indicates that the network path to the target system can be identified through traceroute techniques. Security scanning tools such as Nessus use traceroute to discover intermediate network devices, routers, and hops between the scanner and the target host. This information reveals details about the network infrastructure and routing path used to reach the system.

Solution : Restrict or filter traceroute-related traffic where possible using firewalls and network security controls. Configure network devices to limit the exposure of internal routing information. Implement proper network segmentation and ensure that unnecessary network responses that reveal infrastructure details are minimized.

Business Impact : Exposure of traceroute information may allow attackers to understand the network topology and identify intermediate network devices. This knowledge can assist attackers during reconnaissance by revealing potential network entry points, security devices, or infrastructure components that could be targeted in further attacks.

STAGE 3

Title : Enforce Least-Privilege Access Through Identity-Aware, Application-Specific Access Policies Using Zscaler Private Access (ZPA).

OVERVIEW

In an era where the digital landscape is constantly evolving, organizations face an ever-increasing threat from cyberattacks. The need for swift and effective incident response has become paramount to safeguard sensitive data, protect digital assets, and maintain the trust of stakeholders. In response to this growing challenge, we present a visionary project: the development of an AI-driven incident response platform that empowers cybersecurity teams with the tools to automate and enhance incident triage and response tasks.

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, modern enterprises are rapidly shifting away from legacy VPN-centric remote access models. These conventional approaches often grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement. To address these challenges, this project centers on the implementation of a Zero Trust security architecture, fundamentally operating on the principle of "never trust, always verify." By moving beyond location-based access, we aim to establish a security posture where trust is no longer implicit, and access is determined by granular context rather than network connectivity.

The core of this initiative involves the deployment of Zscaler Private Access (ZPA), a cloud-delivered Zero Trust Access solution designed to create identity-aware, application-specific connectivity. Unlike traditional VPNs that place users on the internal network, ZPA leverages a "service-initiated" model to establish direct, one-to-one connections between authorized users and specific applications, completely hiding the corporate network and IP address space from the internet. This ensures that users connect exclusively to the applications they are permitted to access, based on continuous identity verification and context, rendering the applications invisible to unauthorized users and preventing common attack vectors such as port scanning and distributed denial-of-service (DDoS) attacks.

Ultimately, this project will enforce a least-privilege access model, ensuring users and devices are granted the minimum required access necessary to perform their functions. By decoupling application access from

network access, we will eliminate the risk of lateral movement across the network, as users have no visibility or connectivity to other hosts. This strategic move not only significantly enhances security by reducing the attack surface but also simplifies the user experience and reduces operational overhead associated with legacy remote access infrastructure, positioning the organization at the forefront of secure and efficient access management.

Identity

Zscaler Private Access (ZPA) establishes robust identity verification as the foundational layer of its Zero Trust security model through deep integration with leading enterprise identity providers such as Azure Active Directory, Okta, and SAML-based systems. This continuous authentication process validates not just initial login credentials but also maintains ongoing session verification, confirming user attributes including group memberships, role-based entitlements, and just-in-time privilege elevations throughout the entire access session.

Device posture

Device posture assessment represents ZPA's second critical verification dimension, conducting comprehensive real-time endpoint health checks before permitting any application connectivity. This advanced capability integrates directly with Mobile Device Management (MDM) solutions, Endpoint Detection and Response (EDR) platforms, and native OS security features to evaluate multiple compliance factors simultaneously, including active antivirus protection status, full-disk encryption enforcement, current operating system patch levels, firewall configuration integrity, and jailbreak/root detection on mobile devices.

Application risk

Application risk profiling enables ZPA to implement intelligence-driven, tiered access controls that match security requirements to business criticality across the entire application portfolio. High-risk workloads such as ERP systems, financial transaction platforms, customer relationship management databases, and intellectual property repositories trigger the most stringent verification workflows, combining elevated identity proofs, device posture gates, and continuous behavioral monitoring. Conversely, lower-risk collaboration tools or read-only reporting applications receive appropriately calibrated protections that maintain security without impeding productivity.

Context-aware access

Context-aware access evaluation layers sophisticated behavioral and environmental intelligence atop identity and device verification, creating truly dynamic policy decisions that adapt to real-world risk conditions. ZPA continuously analyzes multiple contextual signals including geographic location, connection time-of-day patterns, source IP reputation scores, network trust classification, and anomalous behavioral deviations from established user baselines. Access requests originating from untrusted geolocations, attempted during off-business hours, traversing known malicious IP ranges, or exhibiting unusual data access patterns trigger immediate policy violations and session termination.

Architecture of ZPA :

The architecture of Zscaler Private Access is designed to provide secure, application-level access without exposing the internal network to the internet. ZPA follows a Zero Trust architecture where applications remain hidden behind the Zscaler cloud and are never directly exposed. The core components include the ZPA Client Connector installed on the user device, the Zscaler Cloud that acts as a broker for secure connections, and the App Connector deployed inside the organization's private network. When a user attempts to access an application, the request is authenticated and verified through the Zscaler cloud before a secure connection is established. This architecture ensures that users connect only to specific authorized applications rather than the entire network, thereby reducing the attack surface and preventing unauthorized access.

Identity-Based Access Control :

Identity-Based Access Control is a fundamental concept in Zero Trust security, where access decisions are made based on the identity of the user rather than their network location. In this model, authentication is performed through an Identity Provider such as Azure Active Directory or other enterprise identity services. The system verifies the user's credentials, role, and group membership before granting access to any application. Additional factors such as device posture, security compliance, and authentication methods like Multi-Factor Authentication (MFA) may also be evaluated. By relying on identity as the primary control mechanism, organizations ensure that only authorized users can access specific resources, significantly reducing the risk of unauthorized access and credential misuse.

Application-Specific Connectivity :

Application-Specific Connectivity ensures that users are granted access only to the applications they are authorized to use rather than the entire network infrastructure. With ZPA, each application is treated as an independent segment, and a secure connection is established only when a verified user requests access to that application. Unlike traditional VPN solutions that place users directly on the internal network, ZPA creates a direct connection between the user and the application through the Zscaler cloud. This approach prevents users from discovering other internal services, servers, or network resources. By limiting access strictly to authorized applications, organizations can significantly reduce the attack surface and protect critical systems from unauthorized exploration or exploitation.

Least Privilege Access Model :

The Least Privilege Access Model ensures that users are granted only the minimum level of access required to perform their job responsibilities. This principle minimizes security risks by preventing users from accessing systems, applications, or data that are not necessary for their role. Within the ZPA framework, policies are configured to define exactly which users or groups can access specific applications. Access is continuously evaluated based on identity, device posture, and contextual factors such as location or time. By implementing least privilege access, organizations can reduce the risk of insider threats, limit the impact of compromised credentials, and prevent attackers from moving laterally within the network.

CONCLUSION

This project focused on improving organizational cybersecurity by identifying vulnerabilities and implementing modern access control mechanisms based on Zero Trust principles. The project was carried out in three stages, each addressing different aspects of security assessment and secure access implementation.

Stage - 1

In **Stage 1**, the study of the OWASP Top 10 vulnerabilities helped identify common security weaknesses that frequently affect web applications. By analyzing issues such as Broken Access Control, Cryptographic Failures, Improper Input Validation, and Authentication Failures, the project highlighted how insecure coding practices and poor system design can lead to serious security risks. Understanding these vulnerabilities provided valuable insights into how attackers exploit web applications and emphasized the importance of secure development practices.

Stage - 2

In **Stage 2**, a vulnerability assessment was performed using the Nessus scanning tool. The scan identified several informational findings such as service detection, OS fingerprinting, DNS hostname discovery, and traceroute information. Although these findings were not critical vulnerabilities, they demonstrated how attackers can gather information about a system during the reconnaissance phase of an attack. The analysis reinforced the importance of minimizing information exposure, properly configuring network services, and implementing strong security controls.

Stage - 3

In **Stage 3**, the project implemented a Zero Trust security approach by deploying Zscaler Private Access to enforce least-privilege access. Instead of providing traditional network-level access through VPNs, ZPA enabled secure, identity-aware, application-specific connectivity. This approach ensured that users could only access the applications necessary for their roles while keeping the internal network hidden from unauthorized users. The implementation significantly reduced the attack surface, prevented lateral movement within the network, and improved overall security management.

FUTURE SCOPE

The work carried out in this project establishes a strong foundation for improving organizational cybersecurity through vulnerability awareness, security assessment, and modern access control implementation. However, cybersecurity is a continuously evolving field, and there are several opportunities to further enhance and expand the solutions implemented in this project.

Stage - 1

In **Stage 1**, which focused on the study of OWASP Top 10 vulnerabilities, the future scope includes integrating secure coding practices directly into the software development lifecycle (SDLC). Organizations can implement automated security testing tools such as Static Application Security Testing (SAST) and Dynamic Application Security Testing (DAST) to continuously detect vulnerabilities during the development process. Additionally, developers can adopt secure coding standards and perform regular security code reviews to minimize the introduction of new vulnerabilities in web applications.

Stage - 2

In **Stage 2**, which involved vulnerability assessment using Nessus, future improvements could include implementing continuous vulnerability monitoring and automated patch management systems. Regular scheduled scans, integration with Security Information and Event Management (SIEM) platforms, and real-time alerting mechanisms can help organizations detect vulnerabilities more quickly and respond proactively. Expanding the assessment to include web application scanning, cloud security scanning, and penetration testing would also provide a more comprehensive security evaluation.

Stage - 3

In **Stage 3**, which implemented Zero Trust access using Zscaler Private Access, the future scope includes expanding the Zero Trust architecture across the entire enterprise environment. This can involve integrating additional security layers such as device posture verification, behavioral analytics, adaptive risk-based authentication, and endpoint detection and response (EDR). Organizations can also extend Zero Trust principles to cloud environments, IoT devices, and internal services to create a fully secure and identity-driven access framework.

Overall, the future development of this project can focus on integrating automated security monitoring, advanced threat detection, and comprehensive Zero Trust security strategies. By continuously improving security practices and adopting modern security technologies, organizations can build a resilient infrastructure capable of defending against evolving cyber threats while maintaining secure and efficient access to critical resources.

Topics Explored :

1. Cybersecurity Fundamentals
2. Web Application Security
3. OWASP Top 10 Vulnerabilities
4. Broken Access Control
5. Cryptographic Security Practices
6. Input Validation and Injection Attacks
7. Authentication and Authorization Mechanisms
8. Vulnerability Assessment Concepts
9. Network Reconnaissance Techniques
10. Zero Trust Security Architecture (ZTA)
11. Identity-Based Access Control
12. Least Privilege Access Model
13. Application Segmentation and Micro-Segmentation
14. Secure Remote Access Models
15. Cloud-Based Security Solutions

Tools Explored :

1. Nessus Scanner

Used for vulnerability scanning to identify security weaknesses, open ports, outdated software, and misconfigurations in systems and networks.

2. Zscaler Private Access

Implemented to enforce Zero Trust security by providing identity-aware, application-specific access to internal applications without exposing the internal network.

3. OWASP Top 10 Framework

Used as a security guideline to study and understand the most critical web application vulnerabilities and their potential impact on application security.

4. Microsoft Azure Active Directory (Identity Provider)

Used for user authentication and identity verification to ensure that only authorized users can access organizational applications.

5. Multi-Factor Authentication (MFA)

Implemented as an additional layer of security requiring users to verify their identity using multiple authentication factors such as passwords and verification codes.

6. https://hackthissite.org

Used as a practical learning platform to understand ethical hacking techniques, web security challenges, and real-world vulnerability exploitation scenarios.